RAPPORT TP 3 – Threat Intelligence et recherche de vulnérabilités

1. Introduction

La **Threat Intelligence** est l'ensemble des informations collectées et analysées sur les menaces afin d'aider les entreprises à anticiper les attaques.
Son rôle en cybersécurité est de :

- identifier les menaces connues,
- comprendre les vulnérabilités exploitées par les attaquants,
- améliorer la défense proactive des systèmes.

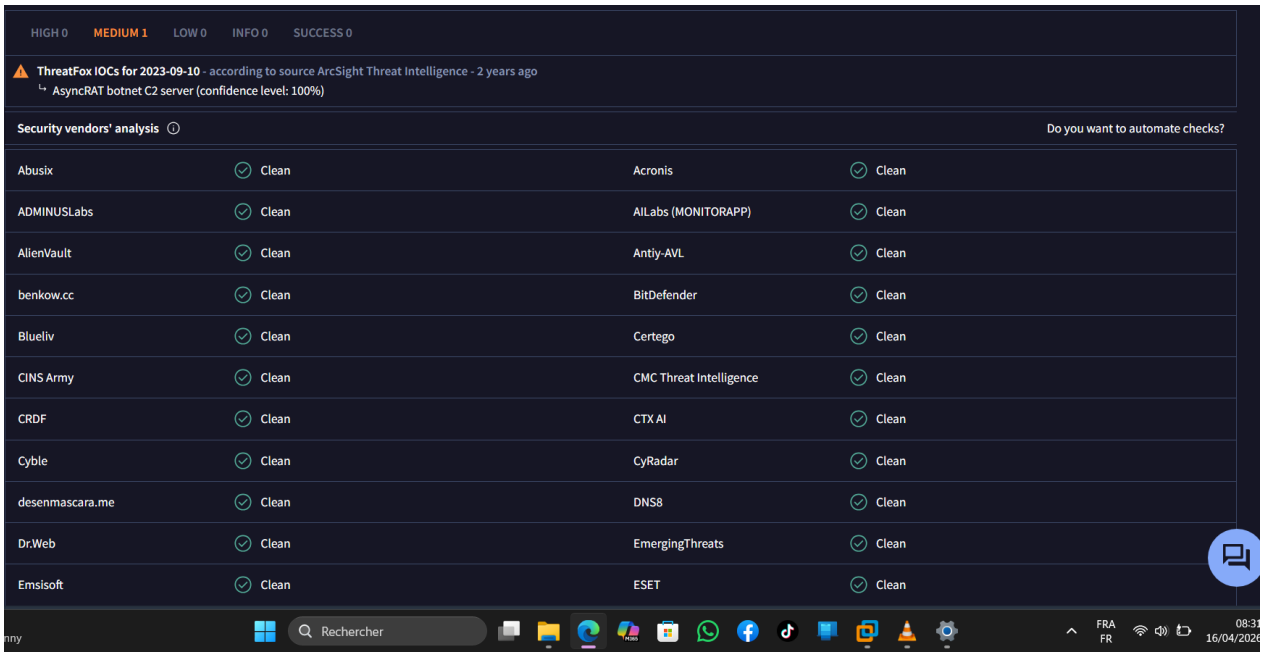
2. Analyse de l'adresse IP (AVEC CAPTURE D'ÉCRAN)

Manipulation : Analyse d'une IP suspecte sur VirusTotal.

Ce que j'ai retenu :

- VirusTotal permet d'obtenir un score de réputation et de voir si une IP est signalée comme malveillante.
- Une IP peut être légitime (ex. serveur DNS), suspecte ou clairement malveillante.
- Cette étape aide à décider si une communication doit être bloquée.

Résultat observé :
Capture d'écran du rapport VirusTotal avec interprétation du score et conclusion sur la dangerosité.



- **MEDIUM = 1** : Il y a **un seul indicateur** classé comme risque **moyen**.
- **HIGH = 0** : Aucune menace critique immédiate.
- **LOW / INFO / SUCCESS = 0** : Pas d'activité bénigne ou réussie détectée.

Conclusion rapide : Ce n'est **pas un signal alarmant** (pas de HIGH), mais il y a **un élément suspect** qui nécessite une vérification manuelle

---

3. Analyse des services (AVEC CAPTURES)

Manipulation : Utilisation des résultats Nmap (TP1) pour identifier un service, puis recherche avec `searchsploit`.

Ce que j'ai retenu :

- Nmap permet de détecter les services actifs et leur version.
- Avec `searchsploit`, on peut rechercher des vulnérabilités connues pour ces services.
- Chaque résultat correspond à un exploit potentiel.

Résultat observé :

- Capture d'écran de la commande `searchsploit` affichant les vulnérabilités associées.

```
PS> ntoguem@kali: /home/ntoguem
Session  Actions  Éditer  Vue  Aide
Shellcodes: No Results

┌──(ntoguem㉿kali)-[/home/ntoguem]
└─PS> searchsploit apache
---------------------------------------------- ---------------------------------
 Exploit Title                                |  Path
---------------------------------------------- ---------------------------------
Apache (Windows x86) - Chunked Encoding (M | windows_x86/remote/16782.rb
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin  | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote C | php/remote/29316.py
Apache - Arbitrary Long HTTP Headers (Deni | multiple/dos/360.pl
Apache - Arbitrary Long HTTP Headers Denia | linux/dos/371.c
Apache - Denial of Service                 | linux/dos/18221.c
Apache - httpOnly Cookie Disclosure        | multiple/remote/18442.html
Apache - Remote Memory Exhaustion (Denial  | multiple/dos/17696.pl
Apache 0.8.x/1.0.x / NCSA HTTPd 1.x - 'tes | cgi/remote/20435.txt
Apache 1.0/1.2/1.3 - Server Address Disclo | multiple/remote/21067.c
Apache 1.1 / NCSA HTTPd 1.5.2 / Netscape S | multiple/dos/19536.txt
Apache 1.2 - Denial of Service             | multiple/dos/20558.txt
Apache 1.2.5/1.3.1 / UnityMail 2.0 - MIME  | windows/dos/20272.pl
Apache 1.3 + PHP 3 - File Disclosure       | multiple/remote/20466.txt
Apache 1.3 - Artificially Long Slash Path  | multiple/remote/20692.pl
Apache 1.3 - Artificially Long Slash Path  | multiple/remote/20693.c
Apache 1.3 - Artificially Long Slash Path  | multiple/remote/20694.pl
Apache 1.3 - Artificially Long Slash Path  | multiple/remote/20695.pl
Apache 1.3 - Directory Index Disclosure    | multiple/remote/21002.txt
Apache 1.3.12 - WebDAV Directory Listings  | linux/remote/20210.txt
Apache 1.3.14 - Mac File Protection Bypass | osx/remote/20911.txt
```

L'exécution de searchsploit apache a affiché une liste exhaustive de vulnérabilités affectant les serveurs Apache. Les résultats sont classés par type d'attaque (DoS, RCE, File Disclosure, etc.) et chaque ligne fournit le chemin d'accès à l'exploit correspondant sur le système. Cette base de données locale est un atout majeur pour un pentester, car elle permet de rechercher des failles même sans accès Internet. Cependant, la majorité des exploits listés concernent des versions anciennes d'Apache, ce qui souligne l'importance de maintenir les services à jour.

---

4. Étude d'une CVE (AVEC CAPTURE)

Manipulation : Recherche d'une CVE (ex. CVE-2021-41773) sur la base NVD.

Ce que j'ai retenu :

- Une CVE est une référence unique pour une vulnérabilité.
- On y trouve la description, le niveau de gravité (CVSS) et l'impact.
- Comprendre une CVE permet de savoir si elle est exploitable à distance et si elle est critique.

Résultat observé :
Capture d'écran de la page NVD montrant la description et le score CVSS.

Recherche de vulnérabilités NVD

CVE-2021-41773 | Avancé | Réinitialisati | Statistiques de l'émission

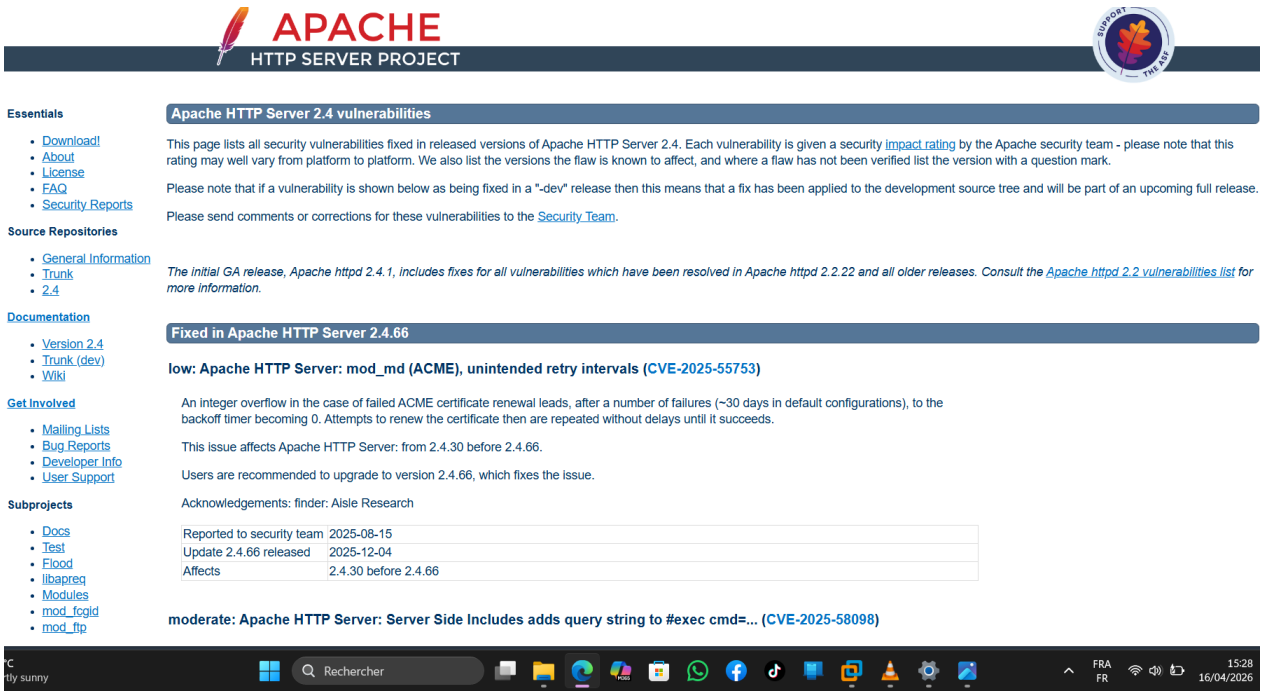
Pour une recherche de phrases, utilisez " »

Momot-clé : CVE-2021-41773

Articles par page : 25 1–2 sur 2

Identifiant	Infos sur le Kev CISA	Date de publication	CNA	Description
CVE-2021-42013	✔	2021-10-07	Fondation Apache Software	Il a été constaté que la correction pour CVE-2021-41773 dans Apache HTTP Server 2.4.50 était insuffisante. Un attaquant pourrait utiliser une attaque de traversée de chemin pour associer des URL à des fichiers en dehors des répertoires configurés par des directives de type Alias. Si les fichiers en dehors de ces répertoires ne sont pas protégés par la convention habituelle...
CVE-2021-41773	✔	2021-10-05	Fondation Apache Software	Un défaut a été identifié lors d'un changement apporté à la normalisation des chemins dans Apache HTTP Server 2.4.49. Un attaquant pourrait utiliser une attaque de traversée de chemin pour associer des URL à des fichiers en dehors des répertoires configurés par des directives de type Alias. Si les fichiers en dehors de ces répertoires ne sont pas protégés par la configuration par défaut habituelle...

Lors de l'analyse des résultats de recherche de vulnérabilités pour la CVE-2021-41773, j'ai constaté qu'il s'agit d'une faille de traversée de chemin dans Apache HTTP Server 2.4.49. Cette vulnérabilité est référencée dans le catalogue CISA KEV, ce qui indique qu'elle est activement exploitée dans la nature. Un attaquant pourrait lire des fichiers sensibles (comme `/etc/passwd`) ou, dans certaines configurations, exécuter du code arbitraire. La CVE-2021-42013 montre que la correction initiale était insuffisante, soulignant l'importance de bien tester les correctifs de sécurité.



APACHE HTTP SERVER PROJECT

Essentials
- Download!
- About
- License
- FAQ
- Security Reports

Source Repositories
- General Information
- Trunk
- 2.4

Documentation
- Version 2.4
- Trunk (dev)
- Wiki

Get Involved
- Mailing Lists
- Bug Reports
- Developer Info
- User Support

Subprojects
- Docs
- Test
- Flood
- libapreq
- Modules
- mod_fcgid
- mod_ftp

Apache HTTP Server 2.4 vulnerabilities

This page lists all security vulnerabilities fixed in released versions of Apache HTTP Server 2.4. Each vulnerability is given a security impact rating by the Apache security team - please note that this rating may well vary from platform to platform. We also list the versions the flaw is known to affect, and where a flaw has not been verified list the version with a question mark.

Please note that if a vulnerability is shown below as being fixed in a "-dev" release then this means that a fix has been applied to the development source tree and will be part of an upcoming full release.

Please send comments or corrections for these vulnerabilities to the Security Team.

The initial GA release, Apache httpd 2.4.1, includes fixes for all vulnerabilities which have been resolved in Apache httpd 2.2.22 and all older releases. Consult the Apache httpd 2.2 vulnerabilities list for more information.

Fixed in Apache HTTP Server 2.4.66

low: Apache HTTP Server: mod_md (ACME), unintended retry intervals (CVE-2025-55753)

An integer overflow in the case of failed ACME certificate renewal leads, after a number of failures (~30 days in default configurations), to the backoff timer becoming 0. Attempts to renew the certificate then are repeated without delays until it succeeds.

This issue affects Apache HTTP Server: from 2.4.30 before 2.4.66.

Users are recommended to upgrade to version 2.4.66, which fixes the issue.

Acknowledgements: finder: Aisle Research

Reported to security team	2025-08-15
Update 2.4.66 released	2025-12-04
Affects	2.4.30 before 2.4.66

moderate: Apache HTTP Server: Server Side Includes adds query string to #exec cmd=... (CVE-2025-58098)

La recherche de la CVE-2021-41773 dans la base NVD a révélé une vulnérabilité critique de traversée de chemin affectant Apache 2.4.49. La présence du symbole ☑ (CISA KEV) indique que cette faille est activement exploitée dans la nature, ce qui élève le niveau d'urgence de correction au maximum. De plus, la CVE-2021-42013 démontre que le correctif initial était insuffisant, soulignant l'importance de tester rigoureusement les mises à jour de sécurité.

---

5. Utilisation avancée de searchsploit

Options présentées :

- `searchsploit -x <chemin>` → permet de lire le contenu d'un exploit.
- `searchsploit -m <id>` → copie l'exploit dans le répertoire courant.
- `searchsploit apache 2.4` → recherche ciblée sur une version précise.

Ce que j'ai retenu :

- Ces options permettent d'aller plus loin dans l'analyse.
- Elles facilitent la compréhension et l'exploitation des vulnérabilités.

---

6. Analyse globale de sécurité

Ce que j'ai retenu :

- Les risques identifiés concernent principalement les services exposés (Apache, SSH).
- Le service le plus dangereux est celui qui présente une vulnérabilité critique exploitable à distance.
- Les actions recommandées sont : mise à jour des logiciels, fermeture des ports inutiles, surveillance proactive.

---

7. Lien avec l'entreprise

Ce que j'ai retenu :

- Un SOC utilise la Threat Intelligence pour anticiper les attaques.
- Les informations publiques (OSINT, CVE, VirusTotal) permettent de détecter les menaces avant qu'elles ne soient exploitées.
- Cela justifie la mise en place d'une veille de sécurité continue.

---

8. Conclusion

Ce TP m'a permis de :

- comprendre que l'information est une arme en cybersécurité,
- savoir rechercher et interpréter des vulnérabilités réelles,
- développer une vision proactive de la sécurité grâce à l'OSINT.

Difficultés rencontrées :

- Interprétation des résultats VirusTotal.
- Compréhension technique des CVE.

Limites de l'analyse :

- Les bases publiques ne couvrent pas toutes les vulnérabilités.
- L'OSINT peut générer trop d'informations, nécessitant un tri rigoureux.